

# APP-5258 · Comprobante de desarrollo

## Validación biométrica Facephi para enrolamiento de Soft Token

|           |                                                                              |
|-----------|------------------------------------------------------------------------------|
| Ticket    | APP-5258 (épica APP-5222)                                                    |
| Bloquea   | APP-5223 — Enrolamiento de Soft Token mediante validación biométrica Facephi |
| Servicios | onboarding-micro-person (.NET 8) · facade-security (NestJS)                  |
| Rama      | feature/APP-5258-facephi-soft-token                                          |
| Proveedor | Facephi Identity API — Identity Validation V2                                |
| Fecha     | 20 de agosto de 2026                                                         |

# 1. Resumen

---

Se integró el servicio **Identity Validation V2** de Facephi en `onboarding-micro-person`, que compara la fotografía del documento del cliente contra su captura facial y ejecuta la prueba de vida pasiva en una sola llamada. Sobre esa integración se expusieron tres operaciones, y en `facade-security` se creó el módulo que las publica hacia la aplicación móvil.

El microservicio concentra toda la lógica: interpreta los códigos de Facephi, aplica las reglas de aprobación, persiste el documento biométrico y cierra la sesión de *tracking*. El facade actúa como paso: reenvía cabeceras, propaga errores y no evalúa resultados.

---

## 2. Alcance ejecutado frente a la descripción original del ticket

La descripción original planteaba cinco endpoints y un flujo con persistencia por pasos. Identity Validation V2 recibe todos los datos en una sola llamada y devuelve el resultado, sin estado intermedio, por lo que el alcance se redefinió con el equipo:

| Descrito en el ticket           | Resultado                                                 |
|---------------------------------|-----------------------------------------------------------|
| POST /facephi/enrollment        | No aplica — no hay registro previo que crear              |
| POST /facephi/document/front    | No aplica — token1 se envía en la misma llamada           |
| POST /facephi/document/back     | No aplica — token2 no existe en Identity V2               |
| POST /facephi/validate          | Implementado                                              |
| GET /facephi/enrollment/{idT24} | Reemplazado por la consulta de documento almacenado       |
| Base de datos MongoDB nueva     | No requerida — se usa la base existente del microservicio |

Se descartó authenticateUser/v2 en favor de Identity V2: el flujo de Soft Token vuelve a pedir al cliente que escanee su cédula, mientras que authenticateUser/v2 habría exigido persistir un template biométrico por usuario.

## 3. Endpoints

### 3.1 onboarding-micro-person

Grupo: `/api/v1/facephi`

| Método | Ruta                           | Descripción                                                |
|--------|--------------------------------|------------------------------------------------------------|
| POST   | <code>/validate</code>         | Valida el documento capturado contra la captura facial     |
| POST   | <code>/validate-face</code>    | Valida la captura facial contra el documento ya almacenado |
| GET    | <code>/document/{idT24}</code> | Indica si el cliente tiene documento biométrico almacenado |

#### POST `/api/v1/facephi/validate`

```
{
  "idT24": "123456789",
  "documentType": "CED",
  "token1": "<token del documento, widget SelphID>",
  "bestImageToken": "<bestImage tokenizada, widget Selphi>",
  "tracking": {
    "extraData": "<token del SDK>",
    "operationId": "<UUID>"
  }
}
```

`tracking` es opcional. `documentType` admite `CED` o `PASSPORT`.

#### POST `/api/v1/facephi/validate-face`

```
{
  "idT24": "123456789",
  "bestImageToken": "<bestImage tokenizada>",
  "tracking": { "extraData": "...", "operationId": "<UUID>" }
}
```

No lleva `token1` ni `documentType`: se reutilizan los almacenados.

#### GET `/api/v1/facephi/document/{idT24}`

```
{ "hasDocument": true, "documentType": "CED" }
```

Nunca expone los tokens almacenados.

## 3.2 facade-security

Grupo: /facephi

| Método | Ruta                | Descripción                                                          |
|--------|---------------------|----------------------------------------------------------------------|
| POST   | /validate-biometric | Publica la validación completa                                       |
| POST   | /validate-face      | Publica la validación con documento almacenado                       |
| GET    | /document/:idT24    | Consulta de documento — endpoint definitivo                          |
| POST   | /document           | <b>Temporal</b> — misma consulta con <code>idT24</code> en el cuerpo |

El `POST /document` existe porque el middleware de cifrado del facade no opera sobre peticiones sin cuerpo, y la aplicación móvil no puede consumir el GET. Ambos delegan en el mismo método del servicio. Se retira cuando el GET quede operativo.

## 4. Integración con Facephi

```
POST {FACEPHI_IDENTITY_API_BASE_URL}/onboarding/v2/identity
```

**Cabeceras:** `x-api-key` (obligatoria) y `family: OnBoarding` (requerida al enviar `tracking`).

**Cuerpo enviado:**

| Campo                       | Origen                                                                              |
|-----------------------------|-------------------------------------------------------------------------------------|
| <code>token1</code>         | Del request, o del documento almacenado en <code>validate-face</code>               |
| <code>bestImageToken</code> | Del request                                                                         |
| <code>method</code>         | Constante del microservicio: <code>FacePhiAuthenticateMethod.TokenToTemplate</code> |
| <code>tracking</code>       | Se omite del payload cuando no viene                                                |

**Respuesta relevante:**

| Campo                                       | Uso                                                                                       |
|---------------------------------------------|-------------------------------------------------------------------------------------------|
| <code>serviceResultCode</code>              | <code>0</code> = el servicio se ejecutó. <b>No significa aprobado</b>                     |
| <code>facialAuthenticationResult</code>     | Coincidencia facial: <code>3</code> POSITIVE, <code>1</code> NEGATIVE, resto no evaluable |
| <code>facialAuthenticationSimilarity</code> | Similitud, <code>1.0</code> = 100 %                                                       |
| <code>passiveLivenessResult</code>          | Prueba de vida: <code>3</code> Live, <code>17</code> NoLive, resto no evaluable           |
| <code>serviceTransactionId</code>           | Identificador de la operación en Facephi, para soporte                                    |

Al cerrar la operación se invoca `FinishTrackingAsync(approved, reason, trackingToken, ct)` cuando el SDK envió `tracking`, con `FacePhiTrackingReason.None` si aprobó y `FacialAuthenticationNotPassed` si no.

## 5. Reglas de aprobación implementadas

---

La validación se aprueba únicamente cuando se cumplen las tres condiciones:

1. `serviceResultCode == 0`
2. Prueba de vida `Live (3)`
3. Coincidencia facial `POSITIVE (3)` — o, si el chequeo propio está activo, que la similitud supere el umbral configurado

Se usa **lista blanca**: sólo el valor `3` aprueba. No se descarta por exclusión, porque la documentación de Facephi muestra un rechazo de prueba de vida que devuelve `0` en lugar de `17`.

El comportamiento del umbral depende de `FACIAL_VALIDATION_CUSTOM_LIVENESS_CHECK`:

- **Desactivado** (valor actual): se confía en el veredicto de Facephi.
  - **Activado**: se aplica además el umbral de similitud del banco.
-

## 6. Variables de configuración

### 6.1 onboarding-micro-person

| Variable                                    | Uso                                    | Observación                            |
|---------------------------------------------|----------------------------------------|----------------------------------------|
| FACEPHI_IDENTITY_API_BASE_URL               | URL base de Facephi Identity API       | Por ambiente                           |
| FACEPHI_IDENTITY_API_KEY                    | Cabecera x-api-key hacia Facephi       | <b>No se versiona:</b> entorno o vault |
| MONGO_DATABASE_NAME                         | Base de datos del documento biométrico | Existente                              |
| FACIAL_VALIDATION_CUSTOM_LIVENESS_CHECK     | Activa el umbral propio                | Hoy en false                           |
| FACIAL_VALIDATION_APPROVED_SIMILARITY_VALUE | Umbral de similitud                    | Definido por Riesgo                    |
| FACIAL_VALIDATION_MODE                      | Average / All                          | Del flujo de onboarding                |
| FACIAL_VALIDATION_CHECK                     | Bypass: SUCCESS , ERROR , NONE         | Ver riesgos, sección 10                |

### 6.2 facade-security

| Variable                   | Uso                        |
|----------------------------|----------------------------|
| ONBOARDING_PERSON_BASE_URL | URL base del microservicio |



## 7. Modelo de datos

**Colección:** `facephi_biometrics` · **Clave de negocio:** `idT24`

| Campo                             | Descripción                                    |
|-----------------------------------|------------------------------------------------|
| <code>idT24</code>                | Identificador del cliente en T24               |
| <code>documentType</code>         | <code>CED</code>   <code>PASSPORT</code>       |
| <code>token1</code>               | Token del documento capturado                  |
| <code>token2</code>               | Captura facial ( <code>bestImageToken</code> ) |
| <code>method</code>               | Método de comparación usado                    |
| <code>tracking.extraData</code>   | Token de seguimiento del SDK                   |
| <code>tracking.operationId</code> | Identificador de operación del SDK             |

**Repositorio** — `FacePhiBiometricRepository` :

- `GetByIdT24Async` — búsqueda por `idT24` , devuelve `null` si no existe.
- `UpsertAsync` — `ReplaceOneAsync` con `IsUpsert = true` filtrando por `idT24` : **actualiza el documento existente, no duplica.**
- `DeleteAsync` — eliminación por `idT24` .

## 8. Archivos intervenidos

---

### 8.1 `onboarding-micro-person`

---

#### Nuevos

- `Application/Facephi/Commands/ValidateIdentityV2Cmd.cs` — comando, validador y handler
- `Application/Facephi/Commands/ValidateFaceOnlyCmd.cs` — comando, validador y handler
- `Endpoints/FacePhi.cs` — grupo `/api/v1/facephi` con los tres endpoints
- `Persistence/FacePhiBiometricRepository.cs` e interfaz
- `Common/Models/Biometric/FacePhiBiometricDocument.cs` y modelos asociados
- `tests/UnitTests/Application/Facephi/` — pruebas de comandos y validadores
- `tests/UnitTests/Endpoints/FacephiEndpointsTests.cs`

#### Modificados

- `Services/Biometric/FacePhiService.cs` — método de Identity V2, cabeceras y payload
- `Common/Interfaces/Biometric/IFacePhiService.cs`
- `Common/Models/Biometric/PassiveLivenessResults.cs` — campos de la respuesta de Identity V2
- `Program.cs` / `ConfigureServices.cs` — registro de repositorio y dependencias

### 8.2 `facade-security`

---

#### Nuevos — todos bajo `src/facephi/`

- `facephi.module.ts`, `facephi.controller.ts`, `facephi.service.ts`
- `dto/validate-biometric.dto.ts`, `dto/validate-face-only.dto.ts`, `dto/get-facephi-document.dto.ts`
- `enums/document-type.enum.ts`
- `types/facephi-response.types.ts`
- `facephi.controller.spec.ts`, `facephi.service.spec.ts`

#### Modificados

- `app.module.ts` — registro de `FacephiModule`
-

## 9. Pruebas

---

`dotnet test --filter "TestCategory=Facephi"` en el microservicio · `npm test` en el facade.

### Microservicio

- Validadores: campos obligatorios, `documentType` admitido y rechazado, `operationId` con formato UUID.
- Mapeo del request hacia Facephi, incluida la omisión de `tracking` cuando no viene.
- Regla de aprobación: combinaciones de coincidencia facial y prueba de vida, con el chequeo propio activo y desactivado.
- Umbral de similitud: rechazo por debajo del valor, y que no se consulte cuando Facephi ya rechazó.
- Persistencia: documento construido correctamente y comportamiento ante fallo del repositorio.
- Cierre de *tracking* con la razón correspondiente según el resultado.
- `validate-face`: cliente sin documento almacenado, uso del token almacenado, y prueba de vida obligatoria.

### Facade

- Reenvío al microservicio con URL, cuerpo y cabeceras correctas.
  - Uso del primer valor cuando las cabeceras llegan como arreglo.
  - Propagación de los estados del downstream y error interno cuando el fallo no proviene de la llamada HTTP.
  - Equivalencia de respuesta entre el GET y el POST temporal de consulta de documento.
-

# 10. Decisiones tomadas

| Decisión                                                    | Motivo                                                                                     |
|-------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| Endpoints genéricos de Facephi, sin semántica de Soft Token | Definido por el equipo: el microservicio expone la capacidad, no el caso de uso            |
| <code>method</code> no viaja en el request                  | Se deriva de un enum en el servidor, para que el cliente no pueda enviar un valor inválido |
| Toda la lógica en el microservicio                          | El facade no interpreta códigos ni toma decisiones                                         |
| Datos mínimos en la respuesta pública                       | El consumidor sólo necesita el veredicto                                                   |
| Se reutiliza la integración existente de Facephi            | No se creó un cliente nuevo ni credenciales nuevas                                         |
| Los tokens biométricos no se registran en logs              | Se registran método, códigos, <code>transactionId</code> y duración                        |

# 11. Pendientes y riesgos conocidos

| # | Punto                                                                                             | Impacto                                                                      | Responsable              |
|---|---------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------|--------------------------|
| 1 | <code>ValidationException</code> no se traduce a <code>400</code> : hoy devuelve <code>500</code> | Los <code>Produce(400)</code> no reflejan el comportamiento real             | Desarrollo               |
| 2 | Fallo de Facephi no se traduce a <code>502 / 504</code> : hoy devuelve <code>500</code>           | El consumidor no distingue error propio de error del proveedor               | Desarrollo               |
| 3 | Falta índice único sobre <code>idT24</code>                                                       | Un upsert concurrente podría duplicar registros                              | Desarrollo / DBA         |
| 4 | El documento se persiste también en rechazos y fallos del servicio                                | Un intento fallido sobrescribe un documento válido anterior                  | Producto / Riesgo        |
| 5 | El documento no guarda marcas de tiempo                                                           | Impide detectar tokens vencidos y depurar registros antiguos                 | Desarrollo               |
| 6 | Sin autenticación en los endpoints del microservicio                                              | La consulta por <code>idT24</code> permite inferir si una persona es cliente | Arquitectura / Seguridad |
| 7 | <code>FACIAL_VALIDATION_CHECK</code> fuerza aprobación en el ambiente QA                          | Una configuración equivocada aprobaría sin validar                           | Seguridad                |
| 8 | GET no consumible desde la app por el middleware de cifrado                                       | Obliga a mantener el POST temporal                                           | Plataforma               |
| 9 | Se desconoce si el <code>token1</code> almacenado caduca                                          | Afectaría a <code>validate-face</code> para documentos antiguos              | Facephi                  |

## 12. Dependencias externas

---

- Credenciales y URL del ambiente de pruebas de Facephi.
  - Un `bestImageToken` válido generado por el widget Selphi para la prueba de extremo a extremo.
  - Definición del método de captura que usará la aplicación móvil.
  - Publicación de las rutas en el gestor de API para los ambientes desplegados.
- 

*Documento de cierre de desarrollo de APP-5258.*